

# امن سازی پایانه های فروش (POS) فروشگاهی زنجیره ای با معماری ZTA

معماری اعتماد صفر (ZTA) یک راهکار امنیت سایبری است که تمرکز خود را از دفاع در لبه شبکه (فایروال های سنتی) به حفاظت مستقیم از منابع (کاربران، دارایی ها و داده ها) منتقل می کند.

اجزای منطقی اصلی ZTA:

- موتور سیاست گذاری (PE): مغز متفکر که تصمیم می گیرد آیا اجازه دسترسی داده شود یا خیر
- مدیر سیاست گذاری (PA): اجراکننده دستورات PE که مسیر ارتباطی را باز یا بسته می کند
- نقطه اجرای سیاست (PEP): دروازه ای که مستقیماً ارتباط بین سوژه و منبع را پایش و کنترل می کند
  - در اینجا PEP به سیستم Agent / Gateway تفکیک شده است

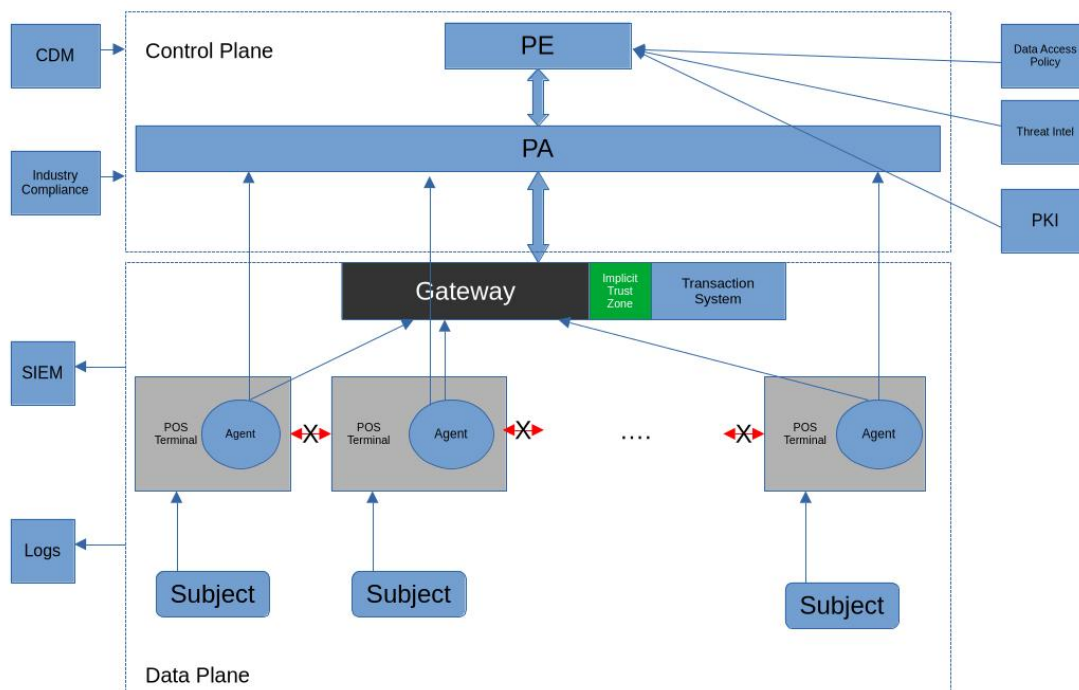
## صورت مسئله

جلوگیری از تزریق بدافزار و سرقت اطلاعات از طریق ایزوله سازی کامل POS ها و محدود کردن ارتباط آن ها فقط به سرور تراکنش

### ۱. طراحی سطح بالا (High-Level Design - HLD)

در این طرح، از مدل عامل/دروازه (Device Agent/Gateway Model) استفاده می کنیم.

- روی هر دستگاه POS یک عامل (Agent) نصب می شود. -> Sandboxing
- یک دروازه منبع (Gateway) در مقابل سرور تراکنش قرار می گیرد. -> DPI
- ارتباطات جانبی (East-West) بین POS ها کاملاً مسدود می شود تا حرکت جانبی (Lateral Movement) بدافزار غیرممکن شود. -> Lateral Movement
- سیستم های SIEM و لاگ ها وارد الگوریتم PE می شوند برای تشخیص ناهنجاری



## ۲. تعریف سیاست های فیلترینگ لایه اپلیکیشن (Policy Definition Application Layer)

```
1. IF Subject=POS_Terminal AND API_Version < v3.0 THEN Access=Deny
2. IF Subject=POS_Terminal AND HTTP_Method != POST AND URI=/checkout THEN
   Access=Block
3. IF Subject=POS_Terminal AND Payload_Contains=Cleartext_Credit_Card THEN
   Access=Block AND Log_Alert
4. IF Subject=POS_Terminal AND Auth-Token=Expired THEN Access=Deny AND
   Request_Reauth
5. IF Subject=POS_Terminal AND HTTP_User_Agent != "RetailPOS_App_v2" THEN
   Access=Drop
```

## ۳. تشخیص ناهنجاری ها (Anomaly Detection)

برای شناسایی ناهنجاری، موتور سیاست‌گذاری (PE) باید از یک الگوریتم اعتماد ضمیمه ای (Contextual TA) استفاده کند

آموزش CTA : با استفاده از لاگ های فعالیت آموزش می بیند. مثال: که به طور تقریبی یک تراکنش POS تقریباً ۱۰kb است و هر ۲-۵ دقیقه رخ می دهد.

- عامل یا Agent روی پایانه های فروش، Application Sandboxing انجام می دهند، برای اینکه اطمینان حاصل شوند تنها اپلیکیشن ها / نرم افزار های تایید شده با شبکه می توانند تعامل برقرار کنند و در محیط خود پایانه با حداقل دسترسی سیستمی قرار دارند
- دروازه تعامل با سرور تراکنش عمل DPI یا بررسی عمیق پکت ها را انجام می دهد، که اطمینان حاصل کنیم تنها درخواست های معتبر API تراکنشی استفاده شده اند
- سیستم SIEM و لاگ های فعالیت به CTA داخل PE اطلاعات را ارسال می کنند تا کار تشخیص ناهنجاری انجام شود

## ۴. مدل سازی تهدید (Threat Modeling)

- جلوگیری از حرکت جانبی: اگر یک POS به بدافزار آلوده شود، چون PEP اجازه هیچ ارتباطی به جز سرور تراکنش را نمی دهد، بدافزار نمی تواند به POS های مجاور سرایت کند.
- پنهان سازی منابع: سرور تراکنش برای هیچ دستگاهی قابل رویت (Discoverable) نیست مگر اینکه ابتدا توسط PEP (Agent / Gateway) تایید هویت شده باشد. این کار جلوی حملات شناسایی و DoS را می گیرد.
- جلوگیری از ورود بد افزار: چون Agent ما کار Sandboxing انجام می دهد حتی اگر بدافزار به سیستم عامل پایانه نفوذ کند نمی تواند دسترسی به شبکه یا پروسه های تراکنشی داشته باشد

## ۵. ابزارهای پیشنهادی برای پیاده سازی (Implementation Toolset)

- Appgate SDP: یک راهکار تجاری برای ایجاد محیط نرم افزارمحور (SDP) که ارتباطات POS را کاملاً ایزوله می کند
- Zscaler Private Access (ZPA): برای مدیریت دسترسی های ابری و محلی پایانه ها بدون نیاز به VPN سنتی
- قوانین iptables (در لایه لینوکس POS) به همراه یک SIEM متن باز مانند ELK: برای مانیتورینگ دقیق و مسدودسازی ترافیک غیرمجاز در لایه عامل